MEDGLOBAL HEALTH - ISO 27001 BGYS DENETİM RAPORU

1. Yönetici Özeti

Bu rapor, 7 ülkede faaliyet gösteren, 4.500 çalışanı bulunan ve sağlık teknolojileri geliştiren MedGlobal Health şirketinin ISO 27001 Bilgi Güvenliği Yönetim Sistemi (BGYS) denetim bulgularını içermektedir. Şirket yönetimi (CEO, CISO ve Direktörler), bilgi güvenliği politikalarının güncel olduğu, ISO 27001 gereksinimlerinin tamamının karşılandığı ve risklerin kontrol altında olduğu yönünde denetim ekibine güvence vermiştir.

Ancak gerçekleştirilen kanıta dayalı bağımsız denetim sonucunda, yönetimin beyanları ile sahadaki uygulama arasında çok ciddi ve kritik tutarsızlıklar tespit edilmiştir. Şirketin ana faaliyet alanı olan "bulut tabanlı hasta yönetim sistemleri" ve bu verilerin barındırıldığı AWS ve Azure ortamları BGYS kapsamı dışında bırakılmıştır. Sistemde 127 adet kritik ve 394 adet yüksek seviyeli açık zafiyet bulunurken, sistemin kalbini oluşturan iç denetim ve yönetim gözden geçirme gibi sürekli iyileştirme mekanizmalarının en son 2023 yılında işletildiği görülmüştür. Mevcut durum, şirketi çok ciddi siber güvenlik, veri ihlali gibi uyum riskleriyle karşı karşıya bırakmaktadır.

2. Sertifika Devam Eder mi?

Değerlendirme Sonucu: Mevcut şartlar altında sertifikanın devam etmesi **mümkün değildir.**

- 3 ay sonra yapılacak olan gözetim denetiminde, tespit edilen çok sayıdaki Majör Uygunsuzluk (Major Nonconformity) nedeniyle şirketin mevcut ISO 27001 sertifikası büyük ihtimalle **askıya alınacak veya doğrudan iptal edilecektir.**

- Sistemin ayakta kalmasını sağlayan İç Denetim ve Yönetim Gözden Geçirme toplantılarının 2023'ten beri usulüne uygun işletilmiyor olması, ISO 27001 standardının temelini oluşturan PUKÖ (Planla Uygula Kontrol et Önlem al) döngüsünün şirkette tamamen çöktüğünü kanıtlamaktadır.

3. ISMS Olgunluk Değerlendirmesi

MedGlobal Health'in Bilgi Güvenliği Yönetim Sistemi olgunluk seviyesi sertifikasyon aldığı tarihten (2023) bu yana gerilemiş ve **"Başlangıç (Ad-hoc) / Tepkisel (Reactive)"** seviyesine düşmüştür.

- **Liderlik ve Yönetişim (Zayıf):** Üst yönetimin desteği ve hesap verebilirliği eksiktir. Bilgi güvenliği politikası Mart 2022'de (Versiyon 1.0) kalmış olup, doküman üzerinde herhangi bir yönetim onayı veya doküman sahibi bulunmamaktadır.

- **Süreç İşletimi (Kopuk):** Süreçler kağıt üzerinde tanımlanmış olsa da (örneğin BCP Planı Temmuz 2022 tarihli) pratikte test edilmemekte ve işletilmemektedir (DR Testi ve Masa başı/Tabletop tatbikatı yapılmamıştır).

- **Sürekli İyileştirme (İşlevsiz):** Proaktif güvenlik yönetimi terk edilmiştir. Açılan Düzeltici Faaliyetlerin (Corrective Actions) bazıları 18 aydır açık statüde bekletilmektedir. Hedefler (ISMS Objectives) belirlenirken hiçbir ölçüm (KPI) ve hedef atanmamıştır.

4. Gözetim Denetiminde Major / Minor Nonconformity (Uygunsuzluk) Analizi (Genel Bakış)

Yaklaşan gözetim denetiminde, hazırladığımız bulgulara istinaden denetçilerin yazacağı temel uygunsuzlukların dağılım beklentisi şu şekildedir:

- **Major Nonconformity (Majör Uygunsuzluk):** Sistemin temel bir gereksiniminin karşılanmaması veya sistemin bütünlüğünü tehdit eden çökmelerdir. Şirketteki Kapsamın (Scope) eksik belirlenmesi (Hasta verilerinin dışarıda bırakılması), İç Denetim yapılmaması, Yönetim Gözden Geçirme kararlarının olmaması ve Düzeltici Faaliyetlerin işletilmemesi doğrudan birden fazla Majör Uygunsuzluk olarak raporlanacaktır. Tek bir majör uygunsuzluk bile sertifikanın askıya alınması için yeterlidir.

- **Minor Nonconformity (Minör Uygunsuzluk):** Sistemin genelini anında tehdit etmeyen ancak prosedürlerden sapmaları ifade eder. Eğitimlerini tamamlamayan 1752 personel bulunması veya varlık envanterindeki eksiklikler bu kapsama girebilir (Ancak varlık envanterindeki 320 sunucu, 1500 laptop ve 412 mobil cihaza karşılık envanterde sadece 127 varlık bulunması sapmanın büyüklüğü nedeniyle Minör'den Majör'e evrilecektir).

Bulgu 4.1-Kapsam Daraltması (Scope): Şirketin ana faaliyet alanlarından olan "bulut tabanlı hasta yönetim sistemleri" ve bu verilerin barındırıldığı "AWS ile Azure ortamları" BGYS kapsamı dışında bırakılmıştır. Ayrıca işlenen "hasta verileri" de kapsam dışındadır.

- **Risk Seviyesi: Critical** (Majör Uygunsuzluk potansiyeli)

- **Root Cause Analysis (RCA):** Yönetimin, uyum zorluklarından ve teknik gereksinimlerin maliyetinden kaçınmak amacıyla kapsamı bilinçli olarak manipüle etmesi. Sistem, şirketin gerçek risk profilini yansıtmamaktadır.

Bulgu 4.2 - İlgili Taraflar (Interested Parties): İlgili taraflar listesinde (Interested Parties.xlsx) yalnızca Müşteriler ve Çalışanlar yer almaktadır. Regülatörler, Sağlık Bakanlığı, KVKK ve GDPR gibi kritik yasal gereksinim sağlayıcılar eksiktir.

- **Risk Seviyesi: High**

- **Root Cause Analysis (RCA):** Yasal ve regülatif uyumluluğun (Compliance) şirket kültürüne ve BGYS'ye entegre edilememesi. Yönetimin sadece müşteri ve iç paydaş odaklı dar bir vizyonla hareket etmesi.

Clause 5: Leadership (Liderlik)

Bulgu 5.1 - Bilgi Güvenliği Politikası: Information Security Policy dokümanı Versiyon 1.0 olup, en son Mart 2022'de güncellenmiştir. Dokümanda yönetim onayı ve doküman sahibi bulunmamaktadır.

- **Risk Seviyesi: High**

- **Root Cause Analysis (RCA):** Üst yönetimin BGYS'yi sahiplenmemesi ve hesap verebilirlik eksikliği. Doküman kontrol süreçlerinin (Clause 7.5) işletilmemesi.

Clause 6: Planning

Bulgu 6.1 - ISMS Hedefleri (Objectives): Belirlenen hedefler (Güvenliği artırmak, Olayları azaltmak, Riskleri azaltmak) için hiçbir performans ölçümü (KPI), hedef değer ve sorumlu (Owner) atanmamıştır.

- **Risk Seviyesi: High**

- **Root Cause Analysis (RCA):** Hedeflerin ölçülebilir olmasını sağlayan "SMART" prensibinin bilinmemesi veya uygulanmaması. Sürecin, sadece denetim için kağıt üzerinde doldurulmuş olması.

Bulgu 6.2 - Risk Yönetimi: Risk değerlendirme metodolojisi (Risk_Methodology.docx) en son 2021'de güncellenmiştir. Risk kütüğünde (Risk Register.xlsx) sadece 18 risk olup, risklerin son güncellemeleri 2021, 2022 ve 2023 tarihlerinde kalmıştır. Şirket için hayati olan MFA zafiyetleri, Yapay Zeka kullanımı, Azure/SaaS riskleri ve Tedarik Zinciri saldırıları değerlendirilmemiştir.

- **Risk Seviyesi: Critical** (Majör Uygunsuzluk potansiyeli)

- **Root Cause Analysis (RCA):** Risk yönetiminin yaşayan bir süreç olmaktan çıkması. Güncel tehdit istihbaratının (Threat Intelligence) risk değerlendirmelerine yansıtılmasını sağlayacak bir sürecin olmaması.

Clause 7: Support

Bulgu 7.1 - Eğitim ve Farkındalık: Toplam 4500 çalışanın 1752'si güvenlik farkındalık eğitimini tamamlamamıştır. Phishing simülasyonunda tıklama oranı %27 gibi çok yüksek bir seviyede olmasına rağmen, bu personele yönelik yeniden eğitim programı bulunmamaktadır.

- **Risk Seviyesi: High**

- **Root Cause Analysis (RCA):** Güvenlik kültürünün çalışanlara benimsetilememesi. İnsan Kaynakları ile Güvenlik birimi arasındaki koordinasyonsuzluk ve riskli davranış sergileyen personeli düzeltici mekanizmaların eksikliği.

Clause 9: Performance Evaluation (Performans Değerlendirme)

Bulgu 9.1 - İç Denetim ve Yönetim Gözden Geçirme: En son iç denetim 2023 yılında yapılmış ve aksiyonlar takip edilmemektedir. Yönetim Gözden Geçirme toplantısı en son 2023'te yapılmış olup katılımcılar, kararlar ve aksiyonlar belirtilmemiştir.

- **Risk Seviyesi: Critical** (Majör Uygunsuzluk)

- **Root Cause Analysis (RCA):** BGYS'nin, sadece 2023 yılındaki ilk sertifikasyonu almak için gerçekleştirilmiş "tek seferlik bir proje" olarak algılanması. Sürekli iyileştirme sisteminin şirkette tamamen terk edilmiş olması.

Clause 10: Improvement (İyileştirme)

Bulgu 10.1 - Düzeltici Faaliyetler (Corrective Actions): Toplam 22 bulgunun sadece 4'ü kapatılmış, 18'i hala açıktır. Açık olan bulguların bir kısmı 18 aydır beklemektedir.

- **Risk Seviyesi: Critical** (Majör Uygunsuzluk)
- **Root Cause Analysis (RCA):** Tespit edilen zafiyetleri gidermek için bütçe, zaman veya personel kaynağı ayrılmaması. Sorunların çözümüne yönelik üst yönetim baskısının olmaması.

6. Annex A Kontrol Bazlı Bulgular, Risk Seviyeleri ve Kök Neden Analizi (RCA)

Annex A 5.9: Asset Inventory (Varlık Envanteri)

Bulgu: Varlık Envanteri (Asset Inventory.xlsx) dosyasında toplam varlık sayısı 127 olarak beyan edilmiştir. Ancak IT operasyon bilgileri incelendiğinde şirkette gerçekte 320 sunucu, 1500 laptop ve 412 mobil cihaz bulunduğu, ayrıca AWS ve Azure bulut ortamlarının kullanıldığı tespit edilmiştir. Şirket varlıklarının %90'ından fazlası envanter dışıdır.

- **Risk Seviyesi: Critical** (Majör Uygunsuzluk)
- **Root Cause Analysis (RCA):** Gölge IT (Shadow IT) sorunu ve varlık yönetimi sürecinin manuel, güncel olmayan yöntemlerle yürütülmesi. IT operasyonları ile BGYS yönetimi arasında entegrasyon olmaması.

Annex A 5.15 & 5.16: Access Control ve Identity Management (Erişim ve Kimlik Yönetimi)

Bulgu 1 (Erişim Gözden Geçirme ve JML): Access Review (Erişim Gözden Geçirme) dosyasının adı "Access_Review_Q1_2024.xlsx" olup, 2026 yılındaki denetim itibarıyla son incelemenin üzerinden 2 yıl geçmiştir. JML (Joiner, Mover, Leaver) süreci işletilmemektedir; 2025 yılında ayrılan John Smith ve Alex Brown ile 2026 yılında ayrılan Sarah White isimli kullanıcıların hesapları sistemde hala "Active" olarak görünmektedir.

Bulgu 2 (Yetki Yönetimi): Şirkette 19 personelin "Domain Admin" yetkisine sahip olduğu ve bu yetkiler için herhangi bir "İş Gereksinimi Belgesi" (Business Justification) bulunmadığı görülmüştür. Ayrıca, mevcut 94 servis hesabının 27'sinin sahibi (Owner) belli değildir ve hiçbir servis hesabında parola rotasyonu (Password Rotation) uygulanmamaktadır.

Bulgu 3 (Zafiyet Yönetimi): En son zafiyet taraması 14 ay önce yapılmış olup, sistemlerde kapatılmamış (Open) 127 Kritik ve 394 Yüksek zafiyet bulunmaktadır.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** "Least Privilege" (En Az Ayrıcalık) prensibinin ihlali. İnsan Kaynakları (İK) departmanının işten çıkış bildirimleri ile IT'nin erişim iptal süreçleri

arasındaki entegrasyonun tamamen kopuk olması. Patch (Yama) ve zafiyet yönetiminin proaktif değil, tamamen terk edilmiş bir süreç olması.

Annex A 5.19: Supplier Security (Tedarikçi Güvenliği)

Bulgu: Şirketin çalıştığı 63 tedarikçiden yalnızca 14'üne risk değerlendirmesi yapılmış, sadece 18'inin sözleşmesinde Güvenlik Maddesi yer almış ve sadece 3'ünden sızma testi talep edilmiştir.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Üçüncü taraf risk yönetim (TPRM) sürecinin işletilmemesi. Hukuk/Satınalma departmanları ile Bilgi Güvenliği departmanı arasındaki süreç entegrasyonunun olmaması.

Annex A 5.23: Cloud Security (Bulut Güvenliği)

Bulgu: Şirketin AWS ve Azure bulut altyapılarını kullanmasına rağmen, bu ortamlar için belirlenmiş bir "Bulut Güvenlik Standardı" ve yapılmış bir "Cloud Risk Assessment" (Bulut Risk Değerlendirmesi) bulunmamaktadır.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Bulut ortamlarının (AWS, Azure) BGYS kapsamı dışında bırakılmış olması (Clause 4 eksikliği) sebebiyle bu alanlardaki güvenlik yönetiminin tamamen inisiyatife kalması.

Annex A 5.24: Incident Management (Olay Yönetimi)

Bulgu: SOC (Security Operations Center) Dashboard verilerinde 14 Malware, 7 Phishing ve 3 Brute Force olmak üzere toplam 24 güvenlik vakası tespit edilmişken, resmi olay kütüğünde (Security_Incidents.xlsx) sadece 3 olay kayıtlıdır. Meydana gelen olaylar için Olay Sınıflandırması (Incident Classification), Kök Neden Analizi (Root Cause Analysis - RCA) ve Çıkarılan Dersler (Lessons Learned) uygulanmamaktadır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Operasyonel güvenlik ekipleri (SOC) ile BGYS/Risk yönetim ekipleri arasında iletişim olmaması. Olay müdahale süreçlerinin (Incident Response) resmi bir prosedür yerine anlık müdahalelerle yürütülmesi.

Annex A 5.30: ICT Readiness for Business Continuity (İş Sürekliliği)

Bulgu: İş Sürekliliği Planı (BCP) en son Temmuz 2022'de güncellenmiştir. Bugüne kadar hiçbir Felaket Kurtarma (DR) Testi veya Masa başı (Tabletop Exercise) tatbikatı yapılmamıştır. RTO (Kurtarma Zaman Hedefi) belirlenmiş olmasına rağmen, hasta verisi işleyen bir sağlık teknolojileri şirketi olmasına karşın RPO (Kurtarma Noktası Hedefi) belirlenmemiştir.

- **Risk Seviyesi: Critical** (Majör Uygunsuzluk)
- **Root Cause Analysis (RCA):** İş Sürekliliği sürecinin şirketin gerçek felaket senaryoları (Ransomware, Bulut kesintisi vb.) üzerinden değil, sadece denetimde doküman sunmak

amacıyla kağıt üzerinde tasarlanmış olması. İş Birimlerinin (BIA - İş Etki Analizi) sürece dahil edilmemesi.

7. Yönetim Sunumu (Executive Briefing)

Sayın MedGlobal Health Yönetim Kurulu ve Üst Yönetimi,

Bilgi Sistemleri Denetim ekibi olarak gerçekleştirdiğimiz ISO 27001 iç denetim faaliyetleri sonucunda ulaştığımız temel bulgular aşağıda özetlenmiştir:

1. **Algı ve Gerçeklik Arasındaki Uçurum:** Yönetim beyanlarında "sistemlerin kontrol altında olduğu ve sertifika gereksinimlerinin karşılandığı" belirtilmiş olsa da, sahadaki kanıtlar BGYS'nin 2023 yılından bu yana işletilmediğini ve sertifikanın "kağıt üzerinde" kaldığını göstermektedir.
2. **Sertifikasyon ve Uyum Riski:** AWS, Azure ve Hasta Verilerinin kapsam dışında tutulması ve İç Denetim/Yönetim Gözden Geçirme süreçlerinin olmaması nedeniyle 3 ay sonraki gözetim denetiminde **sertifikanın iptali veya askıya alınması** kesin görülmektedir. Ayrıca Sağlık Bakanlığı, KVKK/GDPR gibi yasal gereksinimlerin kapsamda olmaması ciddi ceza riskleri barındırmaktadır.
3. **Kritik Siber Güvenlik Zafiyetleri:**
    - 14 aydır taranmayan sistemlerde 127 kritik ve 394 yüksek zafiyet açık beklemektedir.
    - İşe giriş-çıkış süreçlerindeki kopukluk nedeniyle ayrılan personelin erişimleri aylarca açık kalmaktadır.
    - 19 adet sahipsiz ve gerekçesiz Domain Admin hesabı, olası bir "Ransomware" saldırısında şirketin tüm ağının (ve kurtarma noktası/RPO'su olmayan verilerinin) geri dönülemez şekilde şifrelenmesine yol açabilir.

Acil Aksiyon Planı (Öneri): Gözetim denetimine 3 ay kalmışken acilen bir "Kriz Yönetim Komitesi" kurulmalı; kapsamın doğru belirlenmesi, varlık envanterinin gerçek verilerle (320 sunucu, 1500 laptop vb.) güncellenmesi, sahipsiz yetkili hesapların (Domain Admin ve Servis hesapları) anında pasife alınması ve açık durumdaki düzeltici faaliyetlerin (Corrective Actions) bütçe/kaynak ayrılarak hızla kapatılması gerekmektedir.